

이벤트 태크노미 스펙 — 인증보안계

목적: 인증보안계에서 생산되는 사용자 행동을 **append-only 이벤트**로 **표준화**하고, FDS 를 엔진.이상거래 조사 에이전트.감사가 **동일한 이벤트 로그**를 **되읽어 소비**하도록 정의한 태크노미. **정보 기준:** 실제 적용된 Flyway 마이그레이션(V2~V26). 컬럼.트리거는 docs/auth_security_ddl_design.md 정보를 따른다. **한 줄 요약:** 생산(append) → 접합점(이벤트 로그) → 소비(read-back). 로그를 "기록"이 아니라 "판단 가능한 신호"로 설계한다.

1. 설계 원칙 (태크노미 거버넌스)

#	원칙	내용
1	Append-only	이벤트는 갱신·삭제하지 않고 새 행으로만 적재. 상태 변화는 이력 테이블에 누적(*_history , login_attempt , certificate_use , fds_detection ...).
2	네이밍 통제	snake_case , 접미사 규칙 — _hash (단방향 해시) · _encrypted (AES-256 암호문) · _at (TIMESTAMPZ) · _yn (CHAR(1) T/F) · _code (코드값).
3	값 집합 = 코드/CHECK로 고정	자유서술 금지. 상태·유형은 CHECK 제약 + 도메인 상수(cust_code_master 소프트 참조, 정본은 도메인 상수).
4	PII 등급 명시	주민번호=암호문(rrn_encrypted)만 보관·평문 미보관, 코드·비밀번호·PIN·토큰=해시, IP·UA=유사식별자.
5	낙관적 락 + Soft Delete	모든 테이블에 version (JPA @Version) + deleted_at / deleted_by (full audit).
6	버전 관리형 진화	이벤트/컬럼 변경은 Flyway 마이그레이션으로만. 파괴적 변경은 신규 컬럼/테이블로(예: V18 rrn_encrypted · consumed_yn 추가).

2. 이벤트 카탈로그

표기: PII/보안 열의 🔒=해시, 🔑=암호문, △=유사식별자(IP/UA/디바이스). 소비 열 — FDS=를 엔진, AGENT=조사 에이전트, AUDIT=감사.

2.1 로그인 · 세션 · 토큰

이벤트	트리거	핵심 필드	소비	PII/보안
login_attempt	모든 로그인 시도(성공·실패)	attempted_login_id · channel_code · ip (+ ip_country_code) · user_agent · device_fingerprint_hash · success_yn · failure_reason_code · login_attempted_at	FDS(LOGIN-실패 횟수), AGENT	🔒 △ · customer_id / device_id nullable(미존재 ID-미등록 기기 시도 허용)
login_session	로그인 성공 시 세션 발급	session_id (PK) · session_status_code (ACTIVE/EXPIRED/LOGGED_OUT/FORCED_OUT) · mfa_completed_yn · session_expiry_at · session_end_reason_code	세션관리 · 차단 실행(강제 종료 =FORCED_OUT)	—
qr_login_token	QR 로그인 플로우 (PENDING→SCANNED→APPROVED)	qr_token_hash · qr_status_code · request_ip · scanned_at / approved_at	세션 발급	🔒 · customer_id (스캔 후) · session_id (승인 후) 확정
api_token	토큰 발급/폐기	token_type_code (ACCESS/REFRESH/OAUTH) · token_hash · token_issued_at / token_expiry_at / token_revoked_at	인증 전파 · Rotation	🔒 · 세션과 순환참조 (DEFERRABLE)

2.2 인증수단 사용

이벤트	트리거	핵심 필드	소비	PII/보안
certificate_use	금융인증서 서명·검증(로그인/거래서명)	purpose_code (LOGIN/TXN_SIGN/CONTRACT_SIGN) · verification_result_code · failure_reason_code · signed_data_hash · request_ip · certificate_used_at	FDS(CERT_USE-인증서 실패 횟수→CERT_FAIL_BLOCK), AGENT	🔒 △
mobile_auth	SMS/PASS 인증코드 발송·검증	method_type_code · telecom_carrier_code · recipient_phone_number · code_hash · verified_yn · attempt_count	본인확인 선행	🔒 · 전화번호(PII) · customer_id nullable(가입 전)
identity_verification	본인확인기관 확인 완료	agency_code (NICE/KCB/SCI/PASS) · ci_value (연계정보) · name / birth_date / gender · rrn_encrypted · consumed_yn · identity_verified_at	가입 · 동일인 식별	🔑 주민번호 암호문(평문 미보관, V18) · customer_id nullable(SIGNUP)

2.3 자격

이벤트	트리거	핵심 필드	소비	PII/보안
password_history	비밀번호 변경	password_hash · change_channel_code · change_reason_code · change_ip	FDS(PW_CHANGE-찾은 변경 MONITOR)	🔒

2.4 고객 상태 이력 · 2.5 감사 (고객계 도메인)

이벤트	트리거	핵심 필드	소비	비고
customer_status_history	고객 상태 전이	from_status / to_status (ACTIVE/DORMANT/SUSPENDED/CLOSED) · is_system_auto	생애주기·리텐션	고객계
customer_grade_history	고객 등급 변경	등급 전/후 · 사유	세그먼트	고객계
customer_access_log	직원의 고객정보 접근	actor(employee) · 대상 고객 · action	AUDIT	고객계(행위자 감사)

2.6 FDS

이벤트	트리거	핵심 필드	소비	PII/보안
fds_detection	FDS 를 히트 시	fds_rule_id · event_type_code · event_reference_id (거래계 soft ref) · fds_detected_at · status_code (PENDING/CONFIRMED/FALSE_POSITIVE)	AGENT(get_fds_history) · 사고처리	—
fds_incident	탐지 → 사고 처리	incident_type_code · process_status_code · fss_reported_yn (금감원 신고) · handler_employee_id	사고 대응	—

3. 소비 (Consumption) — 로그를 판단으로

3.1 FDS 룰 엔진 (실제 구현)

- fds_rule.condition_json = {window, threshold} → 시간창 내 이벤트 COUNT ≥ 임계 → BLOCK / CHALLENGE / MONITOR.
- fds_rule.target_event_code (LOGIN/CERT_USE/PW_CHANGE/DEVICE_REG/TRANSFER)가 이벤트 타입 텍소노미에 매핑 → 임계·윈도우만 바뀌 코드 수정 없이 룰 확장.
- 운영 룰(V8 시드): LOGIN_FAIL_BLOCK_10 (30분 10회→BLOCK) · CERT_FAIL_BLOCK_5 (10분 5회→BLOCK) · PWD_CHANGE_MONITOR_3 (1일 3회→MONITOR).
- 결과는 fds_detection (append) → BLOCK 시 즉시 차단(CUST_060).

3.2 조사 에이전트 (개인 프로젝트 · LangGraph)

- get_auth_events (login_attempt·certificate_use 등) · get_fds_history (fds_detection)를 read-back으로 조회.
- 이상도 점수가 아니라 법적 책임 순 우선순위로 조사 큐 재정렬 → 경쟁 가설 평가 → 신뢰도 계산 → 권고 → HITL.

3.3 감사

- customer_access_log — 직원 행위자 기반 접근 감사.

4. 거버넌스 상세

항목	규칙
암호화/해시	_encrypted =AES-256 암호문(rrn_encrypted) · _hash =단방향(password_hash · token_hash · pin_hash · cert_pin_hash · mobile_auth_code_hash · qr_token_hash)
PII 최소수집	주민번호는 암호문만, 평문 미보관. 검증 1건=가입 1건(consumed_yn)으로 재사용 통제
NULL FK 정책	가입 전 본인확인(mobile_auth / identity_verification) · 미존재 ID 로그인 시도(login_attempt) 허용 → 미가입·비정상 시도도 이벤트로 수집
코드 관리	코드 컬럼= cust_code_master 소프트 참조(FK 미설정), 유효성은 도메인 상수에서 검증
순환참조	login_session.token_id ↔ api_token.session_id DEFERRABLE — 세션→토큰→UPDATE→COMMIT 순

5. 확장 (예정)

컬럼	현재	연결 대상
fds_detection.event_reference_id	BIGINT (soft ref)	거래계(결제/수신/여신) 이벤트

컬럼	현재	연결 대상
certificate_use.target_transaction_id	VARCHAR(50) (soft ref)	거래계 거래 테이블

거래계 구축 시 위 두 컬럼 타입을 거래계 PK에 맞춰 동시 통일 → 인증 이벤트 택소노미를 **거래 이벤트까지 확장**.

이 스펙이 증명하는 역량 — 통제 어휘 기반 이벤트 정의 · PII 등급별 거버넌스 · 룰 엔진/에이전트 이중 소비 · Flyway 버전 관리형 택소노미 진화.